SEV-2



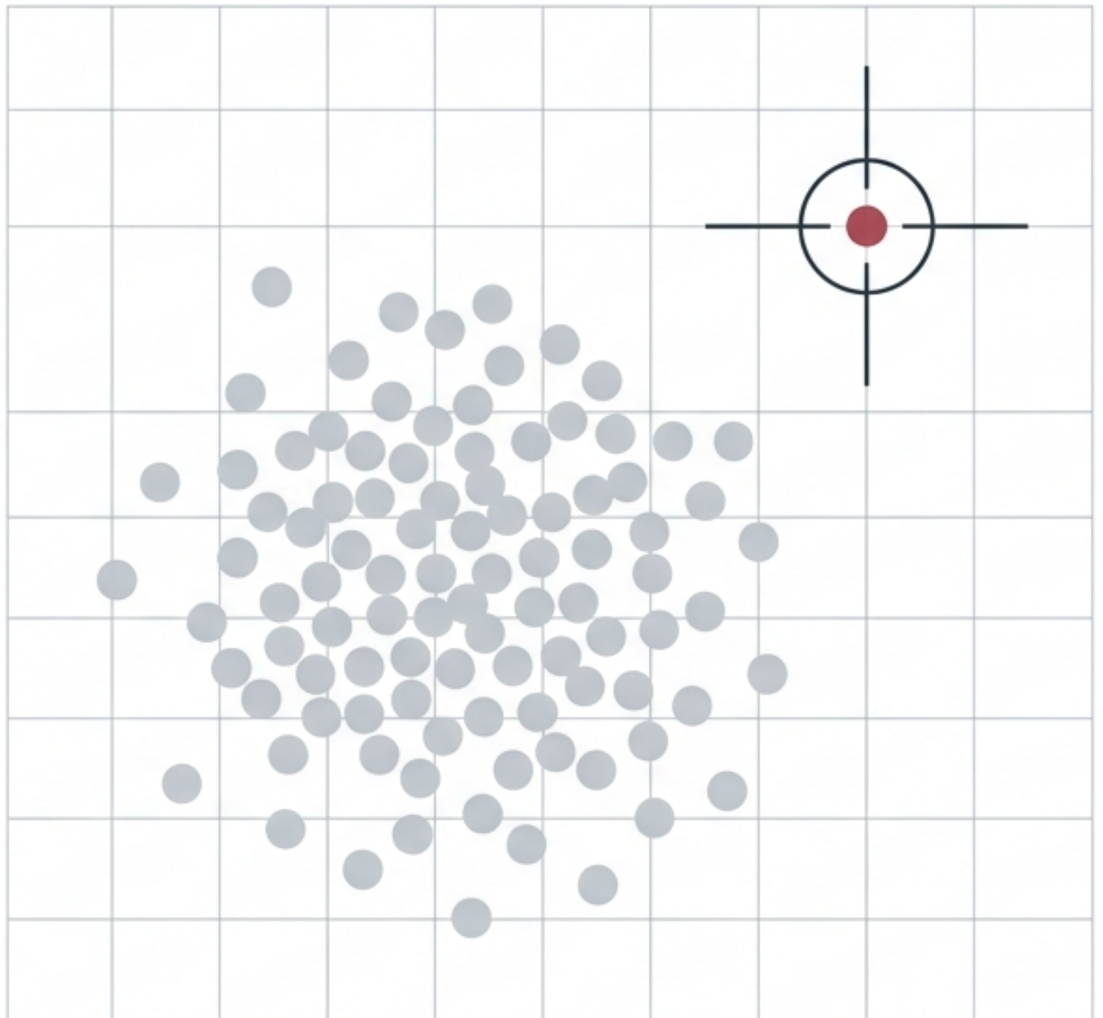
Lab 13: Triage the Security Findings

AWS Day 2 Operations · NorthBank

NotebookLM

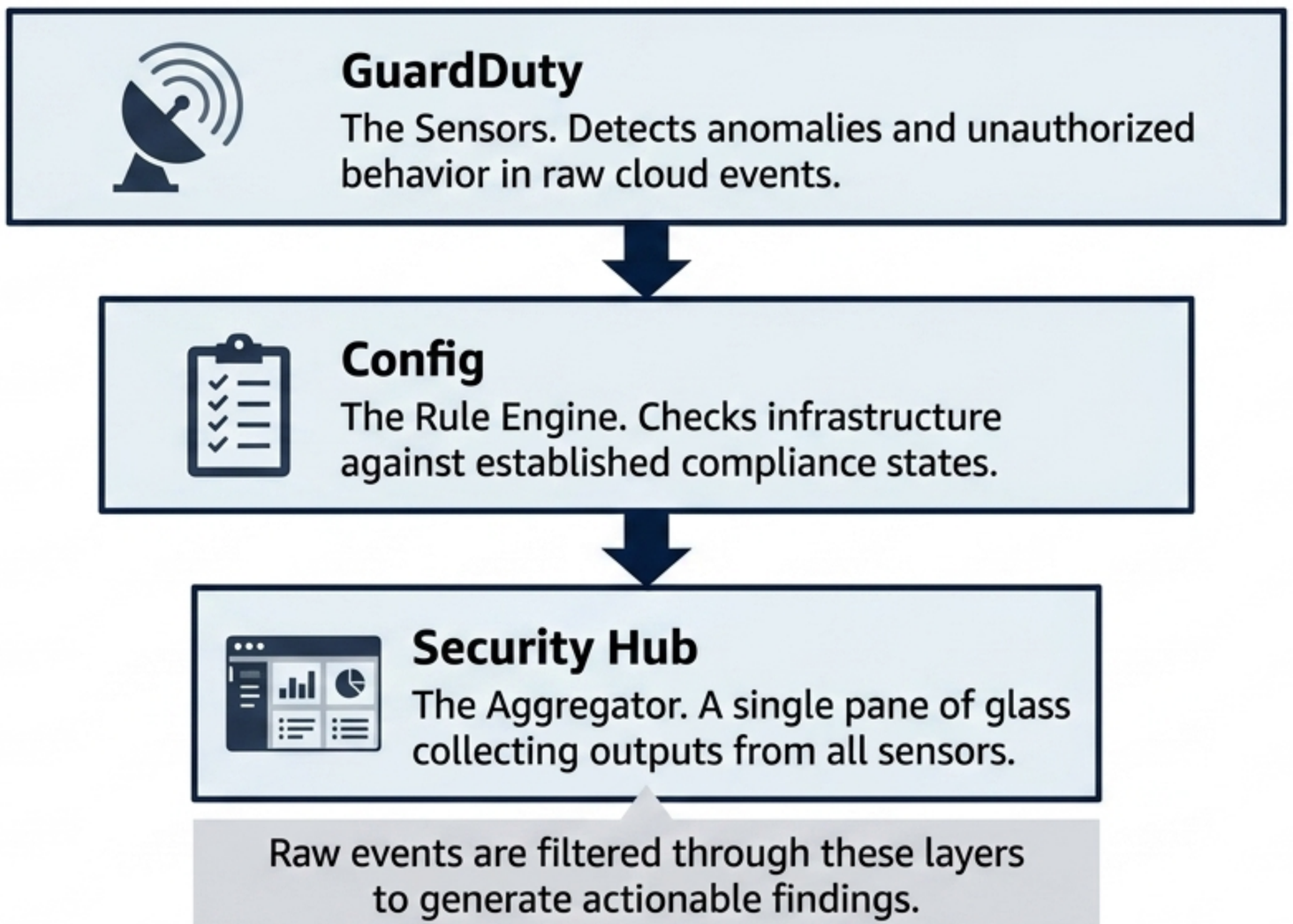
Incident Brief: The Signal in the Noise

Reporter:	Aisha (Security/GRC)
Severity:	SEV-2
Message:	*Security Hub is lighting up. Triage the findings, fix the real one.*



NotebookLM

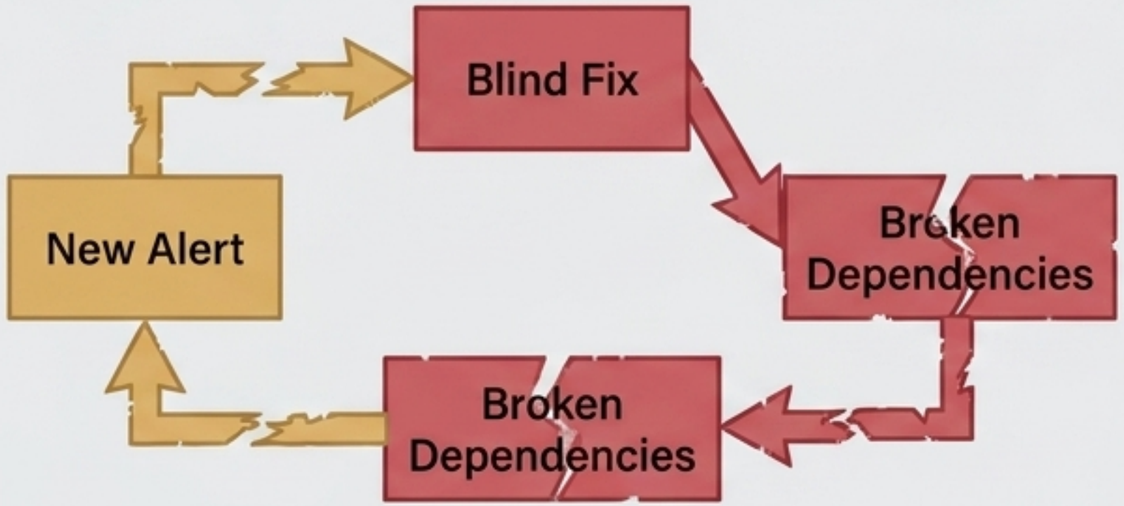
The AWS Security Toolchain automates detection and compliance



NotebookLM

Triage beats whack-a-mole

Reactive: System Fatigue



Strategic: Operational Stability



Most findings are noise — the operational skill is picking the one that’s real.

NotebookLM

Every finding requires a definitive disposition

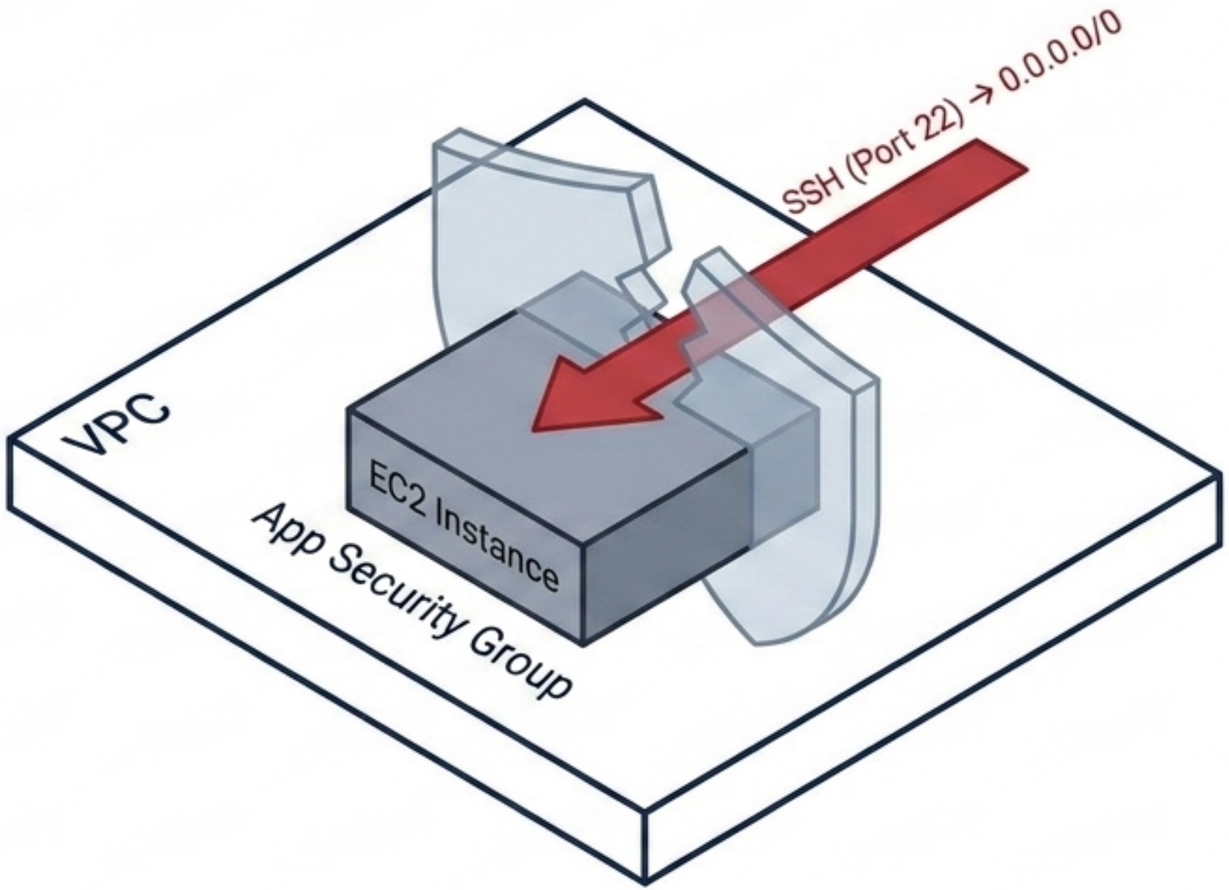
 Fixed	 Suppressed	 Accepted
The root cause of the vulnerability has been actively resolved. System state successfully altered.	Identified as noise, a known false positive, or an irrelevant alert for the specific environment. Hidden from active dashboards.	Acknowledged business risk. The vulnerability is real, but the business accepts the risk due to operational constraints. Documented for audit.

NotebookLM

Step 1: Inducing the SEV-2 fault

```
$ export APP_SG=$(terraform output
-raw app_security_group_id)

$ ./break.sh
```



NotebookLM

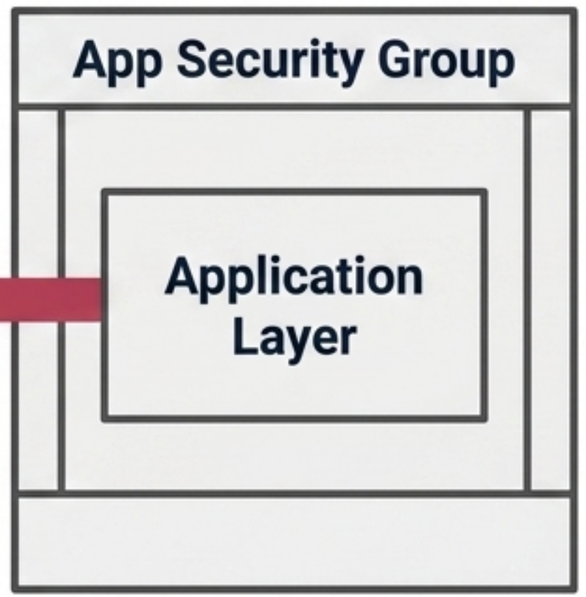
The Anatomy of the Breach: Unrestricted Global Access



0.0.0.0/0
(The Entire Public Internet)

Port 22 (SSH) Open.

This is the ‘real’ finding among the noise. Direct ingress from anywhere allows continuous brute-force attacks against the application layer.



App Security Group

NotebookLM

The SecOps Incident Dossier

Step 2: Investigating the specific security group rules

```
$ aws ec2 describe-security-groups --group-ids $APP_SG

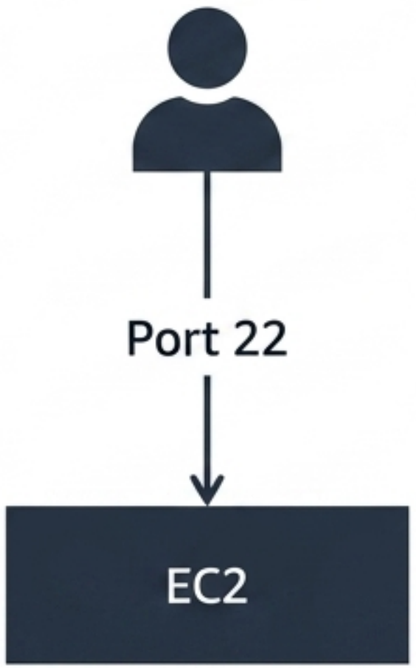
    "IpPermissions": [
        {
            "IpProtocol": "tcp",
            "FromPort": 22,
            "ToPort": 22,
            "IpRanges": [
                {
                    "CidrIp": "0.0.0.0/0"
                }
            ]
        }
    ]
```

Confirmation: The ingress rule is globally open.

NotebookLM

Modernization: Fix with least privilege (SSM > SSH)

Open Perimeter (SSH)



- Requires key pairs
- Requires open inbound ports
- Higher attack surface

Systems Manager (SSM)



- No inbound ports required
- Logged and auditable access
- Granular IAM least-privilege control

NotebookLM

Step 3: Remediating the vulnerability

```
$ aws ec2 revoke-security-group-ingress \
    --group-id $APP_SG \
    --protocol tcp \
    --port 22 \
    --cidr 0.0.0.0/0
```

Note: Because SSM replaces SSH, we remove the ingress rule entirely rather than restricting the IP range.



NotebookLM

Step 4: Verification closes the loop

```
$ aws ec2 describe-security-groups --group-ids $APP_SG
[]
```



SEV-2 Remediated (Fixed)

Query returned zero ingress rules for Port 22.

NotebookLM

Auditors want the decision trail, not zero findings

Reality Check	Perfect security is a myth. Dashboards will never remain at zero findings.
The Day-2 Standard	A documented ‘Accepted Risk’ with a clear justification is far better than a silently ignored alert.
Final Takeaway	The goal of Day-2 Operations is creating an auditable, intentional trail of decisions—whether fixed, suppressed, or accepted.

NotebookLM